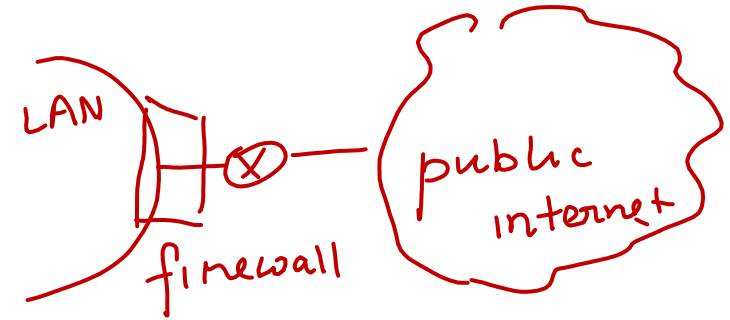


Firewalls

-Dr. Sumana Maiti

Introduction

- Most organizations (eg. universities/companies) have **networks connected to public internet**
- Attackers may attempt to
 - *Infect machines with malware.*
 - *Obtain corporate secrets.*
 - *Map the internal network configurations*
 - *Launch Denial of Service Attack*
- **Firewall systems can be used to detect and/or prevent such attacks.**



Introduction

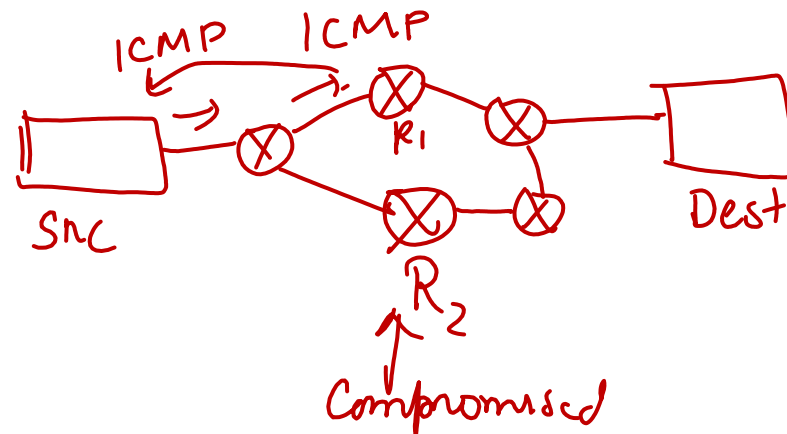
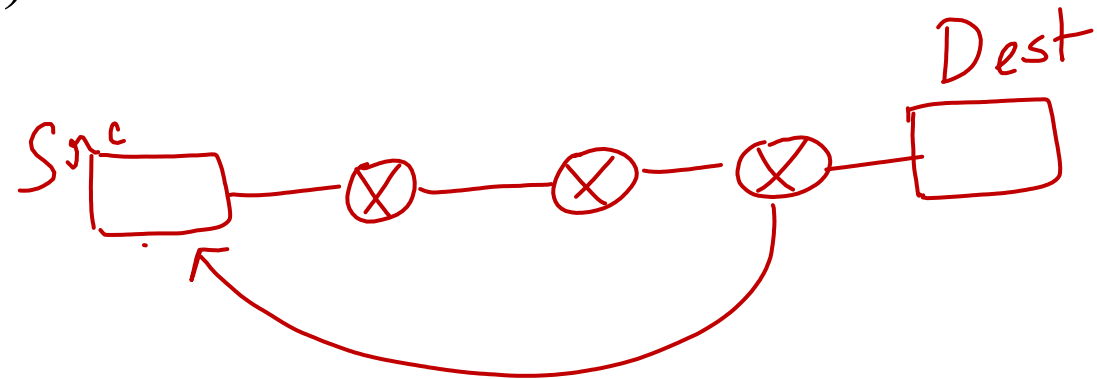
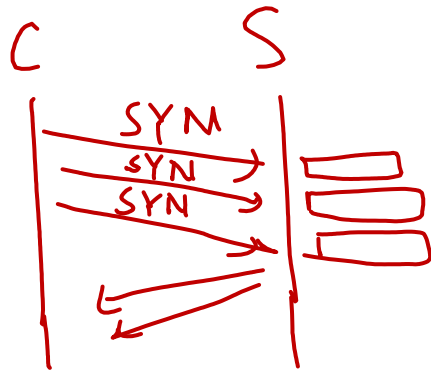
- A Firewall is a combination of hardware and software that controls access between an organization's internal network and the internet.
- Firewall allows some packets to pass and block others based on a given security policy.
- Firewall prevents intruders from attacking internal network.
- Firewall also prevents confidential internal data from getting out.

Properties of a Firewall

- All traffic from outside to inside and vice versa passes through the firewall.
- Only authorized traffic, as defined by the security policy configured by network admin, allowed to pass, other traffics are blocked.
- Firewall itself is designed and maintained in such a way that it is hard to compromise. Unnecessary services on the machine removed. Security policies are updated.
- A Firewall may be implemented
 - In hardware as a stand-alone device (better)
 - On in software on a PC (not expensive)
- Also many routers support basic firewall functionalities.

Different Types of Attacks

- Different ICMP Attacks (Attacker uses Destination unreachable, ICMP redirect, Traceroute)
- TCP SYN Flood
- DNS attack



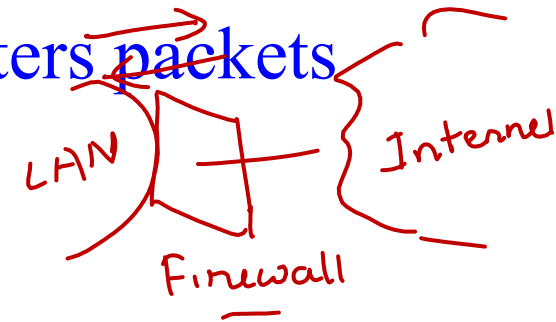
TTL = 1
TTL = 2

Types of Firewall

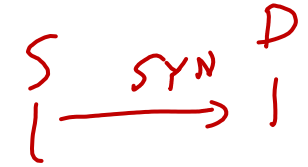
1. Traditional Packet Filter
2. Stateful Packet Filter
3. Application Gateways

Traditional Packet Filter

- Examines each packet in isolation and determines whether the packet should be allowed to pass or should be dropped.
- Traditional packet filter do not store any state. It only filters packets based on rules configured by network administrator.
- Filtering decisions typically based on-
 - **Source IP and/or Destination IP**
 - *Protocol Type - TCP, UDP, ICMP etc.*
 - *TCP or UDP source and destination port*
 - *TCP Flag bits: SYN, ACK, and so on.*
 - *ICMP message type*
 - **Different rules are used for**
 - *Packet entering and leaving the network*
 - *The different router interfaces*



Examples



Policy	Firewall Setting
No outside web access	Drop all outgoing packets to any IP address, port 80
No incoming TCP connections except those for organization's <u>public web server</u>	Drop all incoming TCP SYN packets to any IP except <u>130.207.244.203</u> port <u>80</u>
Prevent audio-video traffic from eating up the available bandwidth	Drop all <u>UDP</u> packets, except <u>DNS</u> <u>packets</u>
Prevent your network from being tracerouted	Drop all <u>outgoing</u> ICMP TTL expired traffic



Examples

Suppose we want to permit internal hosts to initiate or accept Telnet connections to/from only external hosts from a pre-specified list. How can we configure this policy?

Ans: Packet filter forwards only those Telnet packets (Those with a port number of 23) initiated by or to the external hosts from the list.

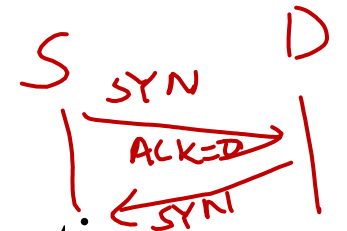
The filtering policy is based on a combination of IP addresses and port numbers.

Examples

Suppose an organization wants to allow its internal hosts to initiate TCP connections to external hosts, but wants to prevent external hosts from initiating TCP connections to internal hosts.

How can we configure this policy?

Ans: We can use the fact that the first packet in every TCP connection has the ACK bit set to 0, but all the other packets have ACK bit set to 1.



Hence, the packet filter can drop all incoming TCP packets with the ACK bit set to 0.

Examples

Consider an organization whose hosts have IP addresses of the form 222.22/16. What type of traffic are allowed and blocked by the access control list in the figure?

Action	Source address	Dest. address	Protocol	Source port	Dest. port	Flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	--
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	--
deny	all	all	all	all	all	all

- The first two rules together allow the internal users to surf the web, but external sources are not allowed to establish a TCP connection with web server.
- The third and fourth rules together allow DNS packets to enter and leave the organization's network.
- *In summary, the access control list blocks all traffic except web traffic initiated from within the organization and DNS traffic.*

Stateful Packet Filter

- Stateful Packet Filters- *(a) tracks TCP connections, (b) use this knowledge to make filtering decisions.*
- The access control list (earlier) - *allows any packet from the outside with ACK bit set to 1 and source port 80 to pass through the filter.*
- This fact can be used by the attacker - by sending malformed packets to internal systems.
- **Solution??**

Action	Source address	Dest. address	Protocol	Source port	Dest. port	Flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
→ allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	<u>ACK</u>
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	--
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	--
deny	all	all	all	all	all	all

- **Solution:** Modify the access control list so that it now blocks incoming packets with ACK bit set to 1 and source port 80.

However, this will prevent the organization's internal users from surfing the web.

- Stateful packet filters solve the problem by tracking all ongoing TCP connections in a connection table

Connection Table

Source Address	Destination Address	Source Port	Destination Port
222.22.1.7	37.96.87.123	12699	80
222.22.93.2	199.1.205.23	37654	80
222.22.65.143	203.77.240.43	48712	80

This is possible because firewall can observe the connection establishment and connection termination

SYN
SYN, ACK
ACK
FIN

The stateful filter includes a new column, “**check connections**” in its access control list. - It indicates that the connection should be checked for the two rules.

Access
Control
List



Action	Source Address	Destination Address	Protocol	Source Port	Destination Port	Flag Bit	Check Connection
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any	
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK	X
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	-	
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	-	X
deny	all	all	all	all	all	all	

Example:

Suppose an attacker attempts to send a malformed packet into the organization's network by sending a packet with -

TCP source port 80 and with the ACK bit set

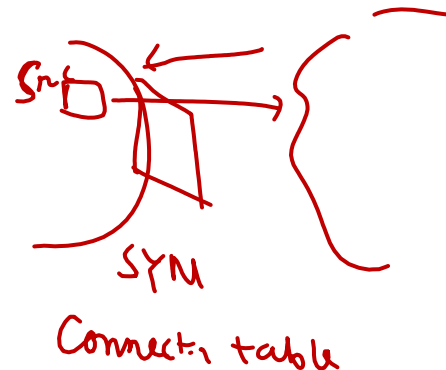
Destination port 12543 and source IP address 150.23.23.155

-> When this packet reaches the firewall, it checks the access control list, which indicates that the connection table must be checked.

The firewall checks the connection table and sees that the packet is not part of an ongoing TCP connection and drops the packet.

Example

- Suppose an internal user wants to surf an external website. First, the user host sends a TCP SYN packet to the web server. Hence, the TCP connection gets recorded in connection table.
- When the web server subsequently sends packets to the user's host (with the ACK bit set) the firewall -
 - checks the table and sees that a corresponding connection is in progress.
 - let these packets pass, thereby not interfering with the internal user's surfing activity.



Handling UDP traffic

- For TCP, maintaining the connection table is easier because of three way handshaking for connection establishment and FIN packets are sent for connection termination.
- However, UDP traffic is not connection-based. Hence, above approach can not be used.
- To handle UDP traffic, a stateful packet filter tracks state using
 - Only source and destination addresses and source and destination port numbers. (using DNS query, it stores source address, destination address, and port numbers.)

Application Gateway

- Traditional packet filter and stateful packet filter perform filtering on the basis of - the contents of IP, TCP/UDP, and ICMP headers.
- Suppose an organization wants to implement the following policies:
 - It wants to allow Telnet to external hosts to a restricted set of Internal users.
 - It wants such privileged users to authenticate themselves first before being allowed to create Telnet sessions to external hosts.

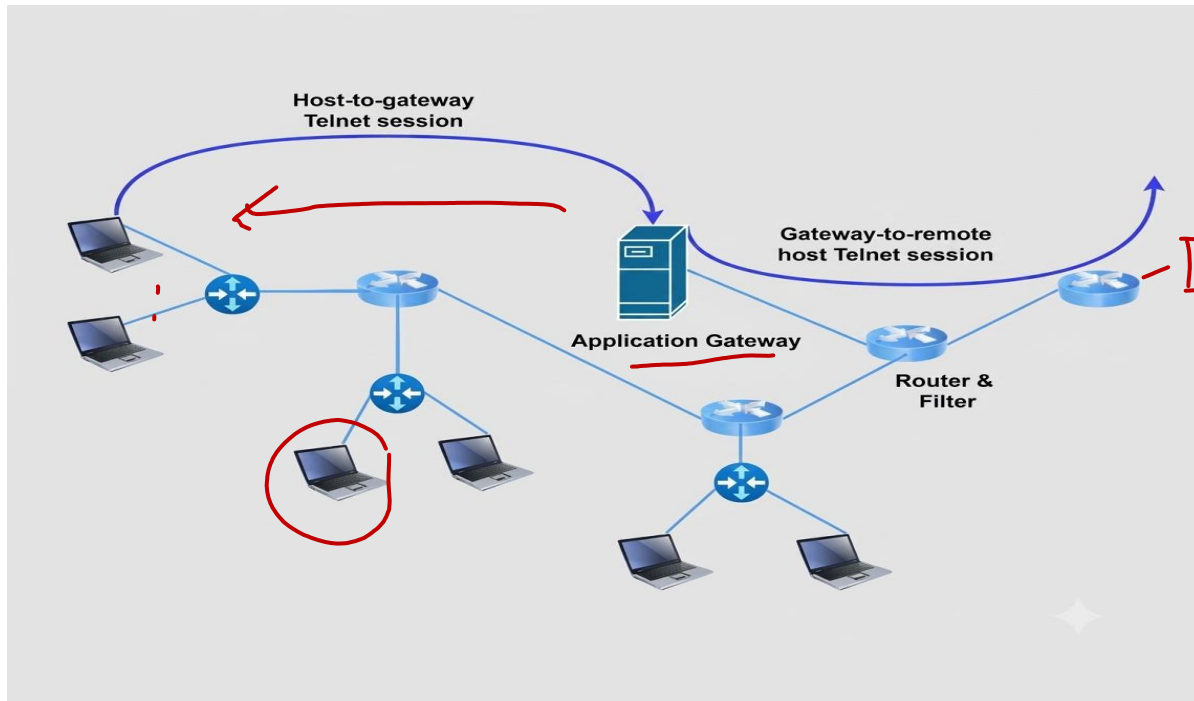
How can the above policies be implemented using packet filters?

- It cannot be implemented using packet filters since information about identities of user is application layer data and is not included in the IP/TCP/UDP/ICMP headers.
- To implement the above policies, application gateways are needed. Application gateways make policy decisions based on application data.
- **Application gateway**
 - Is an application specific server.
 - Through which all application data must pass.

Example

Suppose we want to design a firewall that:-

- (a) Allows only a restricted set of internal users to Telnet to external hosts.
- (b) Prevents all external clients from telneting to an internal host.



The router's filter is configured to block all Telnet connections except those that originate from the IP address of the application gateway- hence inbound Telnet connections are blocked

If an internal user who wants to Telnet to an external host

- The user must first set up a Telnet connection with the application gateway.
- The application gateway prompts user for username and password.
- When this information is supplied, gateway checks to see if the user has permission to Telnet to an external host.
- If not, the Telnet connection from the internal user to the application gateway is terminated by the gateway.

If the user has permission, then gateway

- Prompts the user for the host name of the external host to which user wants to connect.
- Sets up a Telnet connection between gateway and external host
- Subsequently relays data between the external host and user.

Note that the packet filter permits step 2 because gateways initiates Telnet connection to external host

Drawbacks of Application Gateway

- A different application gateway is needed for each application.
- A performance penalty needs to be paid since data is relayed via gateways.